TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HỒ CHÍ MINH

Khoa Công nghệ Thông tin — Lớp K23C

BÁO CÁO ĐỀ TÀI THỰC HÀNH

HỆ THỐNG QUẢN LÝ KHO HÀNG

(INVENTORY)

Triển khai và Quản trị Hệ thống Phần mềm — Đề 5

Họ và tên sinh viên	**Vũ Ngọc Anh Thuyên**
Mã sinh viên	**DTC245200428**
Lớp	K23C — Công nghệ Thông tin
Ngày sinh	14/08/2006
Nhóm	5
Môn học	Triển khai và Quản trị Hệ thống Phần mềm
Người hướng dẫn	**Thầy Vũ Việt Dũng**
Năm học	2025 - 2026

TP. Hồ Chí Minh — 2026

Kho lưu trữ mã nguồn: github.com/thuyenevux-cmd/DTC245200428

BÁO CÁO ĐỀ TÀI THỰC HÀNH

HỆ THỐNG QUẢN LÝ KHO HÀNG (INVENTORY)

Họ và tên sinh viên	Vũ Ngọc Anh Thuyên
Mã sinh viên	DTC245200428
Lớp	K23C – Công nghệ Thông tin
Ngày sinh	14/08/2006
Nhóm	5
Môn học	Triển khai và Quản trị Hệ thống Phần mềm
Tên đề tài	Hệ thống Quản lý Kho hàng (Inventory) – Đề 5
Người hướng dẫn	Thầy Vũ Việt Dũng
Năm học	2025 – 2026

MỤC LỤC

1. Mở đầu
2. Phân tích nghiệp vụ và thiết kế hệ thống
   - 2.1. Nghiên cứu tham khảo
   - 2.2. Quy trình nghiệp vụ
   - 2.3. Mô hình dữ liệu
   - 2.4. Thiết kế giao diện – Design System
3. Kiến trúc hệ thống và môi trường triển khai
4. Kết quả triển khai theo 6 yêu cầu chung
   - 4.1. Mã nguồn trên GitHub và tài liệu hướng dẫn chạy
   - 4.2. Triển khai ứng dụng, cơ sở dữ liệu và công cụ quản lý DB
   - 4.3. Nginx làm reverse proxy kèm HTTPS và security headers
   - 4.4. Prometheus + Grafana giám sát hệ thống
   - 4.5. Loki + Promtail và các truy vấn LogQL
   - 4.6. Các biện pháp hardening
5. Kiểm thử và đánh giá chất lượng
6. Kết luận và hướng phát triển
7. Tài liệu tham khảo
8. Phụ lục

---

1. MỞ ĐẦU

1.1. Bối cảnh

Kho hàng là nơi tồn giữ hàng vật lý trước khi hàng đến tay người mua. Với quy mô vừa và nhỏ, việc theo dõi tồn kho thường nằm trên sổ tay hoặc file Excel: mỗi lần nhập/xuất đều phải cập nhật thủ công, dễ sai số, và không ai biết chính xác mã hàng nào sắp hết. Đề tài này xây dựng một **ứng dụng web quản lý kho hàng** thay thế sổ tay: mọi thay đổi số lượng đều ghi thành **phiếu** và **dòng sổ kho**, tồn kho luôn khớp với lịch sử.

1.2. Mục tiêu

1. Xây dựng ứng dụng web đầy đủ chức năng: nhập hàng, xuất hàng, tồn kho, nhà cung cấp, danh mục mã hàng, tra cứu lịch sử giao dịch.
2. Lưu trữ dữ liệu trên MySQL 8, kèm công cụ quản lý phpMyAdmin.
3. Triển khai **toàn bộ** dịch vụ bằng **Docker Compose** theo đúng yêu cầu chung của môn học.
4. Cấu hình Nginx làm reverse proxy, có HTTPS và security headers.
5. Tích hợp Prometheus + Grafana giám sát ứng dụng, web server và cơ sở dữ liệu.

6. Tích hợp Loki + Promtail, truy vấn log bằng LogQL.
7. Áp dụng các biện pháp hardening: non-root container, network isolation, mật khẩu mạnh, hạn chế quyền, security headers.
8. Đưa mã nguồn lên GitHub với README hướng dẫn chạy và commit rõ ràng.

1.3. Đối tượng sử dụng

VAI TRÒ	NHU CẦU	MÀN HÌNH CHÍNH
Quản lý kho	Biết tồn thực, hàng sắp hết, giá trị tồn	Tổng quan, Tồn kho
Nhân viên kho	Ghi nhập/xuất nhanh, ít thao tác	Nhập hàng, Xuất hàng
Kế toán/đối tác	Tra cứu lịch sử thay đổi	Lịch sử giao dịch

1.4. Phạm vi và giới hạn

Hệ thống quản lý **một kho duy nhất**, không quản lý nhiều kho, lô/serial, barcode, đơn hàng bán ra hay kế toán tài chính. Trường `committed` (số lượng đã cam kết) được dự phòng trong cấu trúc dữ liệu nhưng chưa dùng đến, vì đề tài không yêu cầu nghiệp vụ đơn hàng.

---

2. PHÂN TÍCH NGHIỆP VỤ VÀ THIẾT KẾ HỆ THỐNG

2.1. Nghiên cứu tham khảo

Bốn hệ thống thực tế được khảo sát (truy cập ngày 19/10/2026):

NGUỒN	TRẠNG THÁI	NGUYÊN TẮC RÚT RA
Odoo 19 — *Inventory dashboards*	Truy cập được	Tách dashboard thành ba lớp: vận hành hằng ngày → phân tích hiệu quả → giá trị & sẵn có; cờ riêng cho *tồn âm* và *hàng chậm luân chuyển*
Microsoft Dynamics 365 Business Central — *Inventory and warehouse reports*	Truy cập được	Bộ cột chuẩn cho bảng tồn: SKU, mô tả, đơn vị, vị trí, tồn thực, khả dụng, đã phân bổ, đang đến, tồn an toàn, điểm đặt hàng lại, số lượng đề xuất, nhà cung cấp, ngày PO/ngày nhận cuối
StockFlow (WMS)	Truy cập được	**Phiếu là nguồn sự thật, sổ kho là hệ quả**; số phiếu theo loại (`REC-` , `DEL-` , `ADJ-`); nguyên tắc "mọi thay đổi số lượng đều có dấu vết"; shell sidebar thu gọn được, bảng lọc/sort, toast báo kết quả
StockSight (mã nguồn mở)	Truy cập được	Bộ chỉ số dashboard tối giản: tổng SKU, số SKU dưới ngưỡng, giá trị tồn, xu hướng biến động theo loại giao dịch, cơ cấu giá trị theo nhóm, top sản phẩm, nhật ký biến động

Nguyên tắc được chọn để áp dụng: (1) tách bạch *tồn thực* và *số lượng khả dụng*; (2) phiếu-first với sổ kho bất biến; (3) cảnh báo gắn với con số hành động (ngưỡng nhập lại + số lượng đề xuất); (4) dashboard ưu tiên việc cần làm hôm nay.

Chi tiết nguồn và những gì **không** sao chép được ghi trong `docs/research.md` .

2.2. Quy trình nghiệp vụ



Quy tắc nghiệp vụ được cài đặt:

- **R1** — Mọi thay đổi số lượng đều sinh phiếu có số riêng, theo dạng `NH-2026-0001` (nhập), `XH-2026-0001` (xuất), `ADJ-2026-0001` (điều chỉnh).
- **R2** — Tồn kho không bao giờ âm: hệ thống từ chối phiếu xuất vượt tồn, trả về thông báo nêu rõ mã hàng, số còn và số cần.

- **R3** — Cập nhật tồn và ghi sổ kho nằm trong cùng một transaction: không có trường hợp tồn khớp mà thiếu dấu vết.
- **R4** — Mỗi mã hàng có *ngưỡng nhập lại*; khi tồn thực ≤ ngưỡng, mã hàng xuất hiện ở bảng **Cần nhập gấp** kèm số lượng đề xuất = `ngưỡng × 2 − tồn thực` (tối thiểu 1).
- **R5** — Phiếu nhập bắt buộc có nhà cung cấp; phiếu xuất không có.

2.3. Mô hình dữ liệu

Bảy bảng, thiết kế theo nguyên tắc "phiếu là nguồn sự thật":



BẢNG	Ý NGHĨA	GHI CHÚ
`users`	Tài khoản đăng nhập	Mật khẩu băm bằng bcrypt
`categories`	Nhóm hàng	Dùng để thống kê cơ cấu giá trị tồn
`suppliers`	Nhà cung cấp	Mã, tên, email, điện thoại, địa chỉ
`products`	Mã hàng	SKU (duy nhất), nhóm, đơn vị tính, giá vốn, giá bán, ngưỡng nhập lại
`stocks`	Tồn thực	1 dòng cho mỗi mã hàng, `quantity ≥ 0`, có cột `committed` dự phòng
`stock_documents`	Phiếu nhập/xuất/điều chỉnh	Số phiếu duy nhất, tổng giá trị, người tạo
`stock_movements`	Dòng sổ kho	`quantity > 0` = nhập, `< 0` = xuất, tham chiếu phiếu và mã hàng

Các chỉ mục phục vụ truy vấn: `stock_movements(product_id, created_at)`, `stock_movements(document_id)`, `products(sku)`, `products(category_id)`, `stock_documents(type, created_at)`.

2.4. Thiết kế giao diện — Design System

Giao diện được thiết kế theo một hệ thống thống nhất, tài liệu đầy đủ tại `docs/design-system.md`.

Bảng màu (đều đã đo tương phản theo WCAG 2.1):

TOKEN	HEX	VAI TRÒ	TƯƠNG PHẢN ĐO ĐƯỢC
`color-bg`	`#F1F4F5`	Nền ứng dụng	—
`color-surface`	`#FFFFFF`	Bề mặt thẻ/bảng	—
`color-ink`	`#0E1F22`	Chữ chính	**15,35 : 1** trên nền
`color-ink-muted`	`#4C646B`	Chữ phụ	**5,68 : 1**
`color-primary`	`#0B6B75`	Petrol — thương hiệu, hành động chính	**6,22 : 1** với chữ trắng
`color-accent`	`#C2410C`	Rust — nhấn mạnh, số đề xuất nhập	5,18 : 1
`color-success`	`#146C34`	Còn hàng	6,51 : 1
`color-warning`	`#92400E`	Sắp hết	7,09 : 1
`color-danger`	`#B42318`	Hết hàng, lỗi	5,70 : 1
`color-nav-bg`	`#0E1F22`	Thanh điều hướng	chữ 14,25 : 1

Typography: *Be Vietnam Pro* (SIL OFL 1.1) — font thiết kế riêng cho tiếng Việt, tự host 8 file woff2 (subset `vietnamese` + `latin`, 4 weight), dùng chung cho tiêu đề và nội dung. Số liệu dùng `font-variant-numeric: tabular-nums` để cột số thẳng hàng. Đã kiểm chứng trực tiếp trên trình duyệt: dấu `ă â ê ô ơ ư đ` và các từ *Tồn kho, Phiếu nhập, Nhà cung cấp, Sắp hết* hiển thị đúng ở cả bốn weight.

Icon: bộ Lucide (ISC), vẽ nội tuyến bằng `currentColor`, stroke 1,75 — không trộn bộ, không dùng icon font.

Bố cục: sidebar 248 px (thu gọn được) + thanh trên 56 px + vùng nội dung tối đa 1360 px; lưới 12 cột, thang khoảng cách 4 px, bo góc 4/6/10 px, đúng 2 mức đổ bóng.

Giọng văn giao diện: nội dung nói đúng việc cần làm, CTA là động từ kèm đối tượng ("Ghi nhập hàng", "Ghi xuất hàng", "Thêm sản phẩm"), cấm các cụm sáo rỗng ("hệ sinh thái thông minh", "một cú click", "tối ưu hoá tồn kho"). Chi tiết tại `docs/brand-voice.md`.

---

3. KIẾN TRÚC HỆ THỐNG VÀ MÔI TRƯỜNG TRIỂN KHAI

3.1. Môi trường triển khai

THÀNH PHẦN	PHIÊN BẢN
Máy chủ	Ubuntu Server 26.04 LTS (kernel 7.0), chạy trong máy ảo VMware Workstation 17
Docker Engine	29.7.2 (storage driver `overlayfs`, containerd snapshotter)
Docker Compose	v5.4.0
RAM / ổ đĩa	5,36 GB · 20 GB (sau khi dọn: 5,3 GB trống)

Quá trình chuẩn bị môi trường ghi nhận trong báo cáo:

1. Phát hiện ổ đĩa chỉ còn 1,9 GB trống (91% đã dùng) — dọn cache snap (≈1 GB), xoá bản snap cũ (≈1 GB) và thu nhỏ `swap.img` từ 3,3 GB xuống 1 GB (thu hồi 2,3 GB), đưa dung lượng trống lên **5,3 GB**.
2. Tách mạng `kho-db` (internal) và `kho-net` (bridge) để MySQL không có NAT ra ngoài.

3.2. Sơ đồ kiến trúc



Quyết định thiết kế quan trọng: chỉ Nginx công khai cổng. Mọi công cụ quản trị (phpMyAdmin, Grafana, Prometheus, Loki API) đều nằm sau basic auth của Nginx và chỉ tiếp cận được qua đường dẫn có xác thực.

3.3. Cấu trúc ứng dụng

TẦNG	NỘI DUNG
`src/config`	`env.js` (nạp biến môi trường, chặn chạy production khi thiếu `SESSION_SECRET`), `db.js` (pool mysql2 + helper `transaction`)
`src/middleware`	`auth.js` (đăng nhập, phân quyền), `flash.js` (thông báo một lần), `metrics.js` (bộ đếm định dạng Prometheus), `errors.js`
`src/repositories`	Truy vấn danh mục (`catalog.js`) và tồn kho/sổ kho/dashboard (`stock.js`)
`src/services`	`documents.js` — tạo phiếu trong transaction, kiểm tra tồn, ghi sổ kho
`src/routes`	6 nhóm route: auth, dashboard, products, suppliers, stock (gồm nhập/xuất), movements
`src/views`	EJS: `partials/` (head, sidebar, topbar, foot, pagination, stock-form) và `pages/` (9 trang)
`public`	`css/tokens.css` (token), `base.css` (bố cục), `components.css` (thành phần), `js/app.js`, `vendor/` (font, Chart.js)

Phụ thuộc phía server chỉ gồm `express`, `ejs`, `mysql2`, `bcryptjs`, `cookie-session`, `dotenv`; phía client chỉ có Chart.js (MIT) và font/icon tự host.

---

4. KẾT QUẢ TRIỂN KHAI THEO 6 YÊU CẦU CHUNG

4.1. Mã nguồn trên GitHub và tài liệu hướng dẫn chạy

- Repository: `DTC245200428` (đặt tên theo mã sinh viên theo yêu cầu), đăng trên tài khoản GitHub `thuyenevux-cmd`.
- Lịch sử commit chia theo mốc rõ ràng:

#	COMMIT	NỘI DUNG
1	`chore: khởi tạo dự án và xây dựng design system`	Cấu trúc thư mục, `.gitignore`, `.dockerignore`, `.env.example`, `package.json`, tài liệu design system / brand voice / nghiên cứu / checklist QA
2	`feat: ứng dụng quản lý kho hàng (Express + EJS + MySQL)`	Schema SQL, script migrate/seed, tầng config–middleware–repository–service–route, 9 trang giao diện, token CSS, font/icon tự host
3	`feat: docker compose và nginx reverse proxy kèm hardening`	`docker-compose.yml` 11 service, Dockerfile nhiều tầng chạy non-root, cấu hình Nginx reverse proxy + TLS + security headers, giới hạn tài nguyên
4	`feat: hệ thống giám sát Prometheus + Grafana và log tập trung Loki + Promtail`	Cấu hình scrape, luật cảnh báo, datasource + dashboard Grafana, cấu hình Loki/Promtail
5	`docs: báo cáo tổng hợp, README và ảnh minh họa triển khai`	README hướng dẫn chạy đầy đủ, báo cáo ≥ 10 trang, ảnh chụp từ hệ thống đang chạy

- `README.md` mô tả: yêu cầu cài đặt, lệnh dựng hệ thống, danh sách URL + tài khoản, sơ đồ kiến trúc, bảng chức năng, truy vấn LogQL mẫu, bảng hardening, cấu trúc mã nguồn, bảng giấy phép tài nguyên.

4.2. Triển khai ứng dụng, cơ sở dữ liệu và công cụ quản lý DB

Ứng dụng chạy trong container `kho-app` (node:22-alpine, user `node` uid 1000). Lệnh khởi động:

```
command: ["sh", "-c", "node scripts/ensure-db.js && exec node src/server.js"]
```

`ensure-db.js` chạy migrate (tạo bảng nếu chưa có, idempotent) và chỉ nạp dữ liệu mẫu **khi bảng `products` còn trống** — nên khởi động lại không làm mất dữ liệu đã nhập.

Kết quả kiểm chứng trên máy chủ:

```
→ Đã tạo/cập nhật bảng: categories, products, stock_documents,
                        stock_movements, stocks, suppliers, users
→ Hoàn tất: 28 sản phẩm, 6 nhà cung cấp, 8 nhóm hàng,
            65 phiếu, 135 dòng sổ kho, giá trị tồn 1.838.177.000 đ
[db] kết nối thành công kho_app@mysql:3306/kho_hang
[web] Quản lý kho hàng chạy tại http://0.0.0.0:3000 (production)
```

phpMyAdmin (phiên bản 5.2.3) đăng nhập bằng tài khoản `kho_app`, hiển thị đầy đủ 7 bảng, charset `utf8mb4_unicode_ci`, MySQL 8.0.46 — ảnh chụp ở `docs/screenshots/12-phpmyadmin.png`.

4.3. Nginx làm reverse proxy kèm HTTPS và security headers

Cấu hình Nginx (`docker/nginx/conf.d/kho.conf`):

- **HTTP :8080** trả `301` sang HTTPS :8443.
- **HTTPS :8443** dùng chứng thư tự ký RSA-2048 sinh lúc khởi động container, `ssl_protocols TLSv1.2 TLSv1.3`, `ssl_session_cache shared:SSL:10m`, `server_tokens off`.
- **Security headers** (đặt ở cả hai server block, `always`):

```
x-frame-options: SAMEORIGIN
x-content-type-options: nosniff
referrer-policy: strict-origin-when-cross-origin
permissions-policy: geolocation=(), microphone=(), camera=()
strict-transport-security: max-age=31536000
content-security-policy: default-src 'self'; img-src 'self' data:;
  style-src 'self' 'unsafe-inline'; script-src 'self' 'unsafe-inline';
  font-src 'self'; connect-src 'self'; frame-ancestors 'self';
  base-uri 'self'; form-action 'self'
```

- **Basic auth** cho `/phpmyadmin/`, `/grafana/`, `/prometheus/`, `/loki/`; file `htpasswd` sinh bằng `openssl passwd -apr1` lúc khởi động, quyền `640 root:nginx`.
- `/nginx_status` (stub_status) chỉ cho phép dải mạng nội bộ `172.16.0.0/12`, `10.0.0.0/8`.

Kiểm chứng bằng `curl` trên máy chủ:

```
http 8080 → 301 (chuyển hướng HTTPS)
https 8443 app → 302 (chuyển tới đăng nhập)
https 8443 health → 200
/phpmyadmin/ → không tài khoản=401 | có tài khoản=200
/grafana/    → không tài khoản=401 | có tài khoản=200
/prometheus/ → không tài khoản=401 | có tài khoản=200
```

4.4. Prometheus + Grafana giám sát hệ thống

Prometheus (v3.15.0) scrape 4 mục tiêu, tất cả đều `up`:

```
kho-app    up      (app:3000/metrics — chỉ số do chính ứng dụng xuất)
nginx      up      (nginx-exporter:9113)
mysql      up      (mysql-exporter:9104 — 792 chỉ số MySQL)
node       up      (node-exporter:9100)
```

Bốn nhóm chỉ số mà ứng dụng tự xuất (định dạng chữ chuẩn Prometheus, không thêm thư viện):

```
kho_http_requests_total{method="GET",route="/health",status="200"} 11
kho_db_queries_total 44
kho_stock_documents_total 65
kho_uptime_seconds 786
```

Ngoài ra còn có `docker/prometheus/rules.yml` với 4 luật cảnh báo: ứng dụng không phản hồi (> 2 phút), MySQL exporter không phản hồi, ổ đĩa dưới 15%, RAM dưới 10%.

Grafana (13.2.3) được cấu hình hoàn toàn bằng *provisioning* (không cấu hình tay): hai datasource `prometheus` và `loki`, một dashboard gồm 8 panel — lượt yêu cầu mỗi giây, tổng yêu cầu đã xử lý, thời gian ứng dụng chạy, mức dùng CPU máy chủ, bộ nhớ và ổ đĩa, kết nối và truy vấn MySQL, hoạt động cơ sở dữ liệu của ứng dụng, số mục tiêu giám sát đang hoạt động. Ảnh chụp dashboard lúc chạy thật: `docs/screenshots/15-grafana-dashboard.png` (ghi nhận 132 yêu cầu đã xử lý, CPU 32,9 %, 4/4 mục tiêu UP, 44 truy vấn DB).

4.5. Loki + Promtail và các truy vấn LogQL

Promtail (3.6.11) dùng *docker service discovery* để gom log của các container `kho-*` và đẩy sang Loki (3.6.18). Nginx được cấu hình ghi access log ra `/dev/stdout` để log truy cập cũng nằm trong Loki.

Năm truy vấn LogQL đã chạy thật trên hệ thống:

Truy vấn 1 — số log theo container trong 15 phút

```
sum by (container_name) (count_over_time({container_name=~"kho-.*"}[15m]))
```

```
container_name=kho-app             = 10
container_name=kho-grafana          = 338
container_name=kho-loki             = 10
container_name=kho-mysql            = 31
container_name=kho-mysql-exporter   = 70
container_name=kho-nginx            = 41
container_name=kho-nginx-exporter   = 19
container_name=kho-node-exporter    = 110
container_name=kho-phpmyadmin       = 32
container_name=kho-prometheus       = 186
container_name=kho-promtail         = 2
```

Truy vấn 2 — số lần ứng dụng khởi động trong 1 giờ

```
count_over_time({container_name="kho-app"} |= "production" [1h])
→ 4
```

Truy vấn 3 — số dòng log chứa lỗi trong toàn hệ thống

```
sum(count_over_time({container_name=~"kho-.*"} |~ "(?i)error|exception" [15m]))
→ 71
```

Truy vấn 4 — phân bố mã trạng thái HTTP của Nginx

```
topk(5, sum by (status) (count_over_time({container_name="kho-nginx"} | regexp "HTTP/1.1\" (?P<status>[0-9]{3})" [15m])))
→ status=301 = 3
```

Truy vấn 5 — top 5 đường dẫn được truy cập

```
topk(5, sum by (path) (count_over_time({container_name="kho-nginx"} | regexp "\"GET (?P<path>[^ ?\"]+)" [15m])))
→ path=/ = 6 | path=/auth/login = 6 | path=/health = 6 | path=/nginx_status = 3
```

Mẫu dòng log thu được từ ứng dụng và Nginx:

```
[db] kết nối thành công kho_app@mysql:3306/kho_hang
[web] Quản lý kho hàng chạy tại http://0.0.0.0:3000 (production)
172.18.0.1 - - [19/Oct/2026:15:47:41 +0000] "GET /nginx_status HTTP/1.1" 301 162 "-" "NGINX-Prometheus-Exporter/ ... "
```

4.6. Các biện pháp hardening

#	BIỆN PHÁP	CÀI ĐẶT	KIỂM CHỨNG
1	**Non-root container**	`app` chạy user `node` (uid 1000); `prometheus`, `grafana`, `loki`, `promtail`, `phpmyadmin`, `mysql-exporter` chạy user không phải root; Nginx chỉ cấp 4 capability tối thiểu, worker chạy user `nginx`	`CapEff: 0000000000000000`, `NoNewPrivs: 1` trong container ứng dụng
2	**Network isolation**	Mạng `kho-db` đặt `internal: true` (không NAT); MySQL, phpMyAdmin, mysql-exporter chỉ nằm trong mạng này	`docker network inspect kho-db` → `Internal: true`
3	**Không mở cổng DB**	Chỉ Nginx có `ports`; MySQL/phpMyAdmin/Grafana/Prometheus/Loki không publish	`docker compose ps` chỉ hiện `0.0.0.0:8080` và `0.0.0.0:8443`
4	**Mật khẩu mạnh**	`scripts/gen-secrets.sh` sinh mật khẩu ngẫu nhiên 28 ký tự cho MySQL root/app/exporter, Grafana, session, tài khoản giám sát; `.env` không commit	File `.env` trong `.gitignore`; mật khẩu không xuất hiện trong mã nguồn
5	**Hạn chế quyền DB**	Ứng dụng dùng user `kho_app` chỉ trên database `kho_hang`; user `exporter` chỉ có `PROCESS, REPLICATION CLIENT, SELECT`; MySQL chạy với `--skip-name-resolve`	Script `db/init/10-monitoring-user.sh` tạo user giám sát với đúng 3 quyền đó
6	**Security headers + TLS**	6 header bảo mật, TLS 1.2/1.3, HSTS, `server_tokens off`, giới hạn kích thước request 1 MB	Xem mục 4.3
7	**Xác thực hai lớp**	Nginx basic auth + đăng nhập riêng của ứng dụng (bcrypt), Grafana (auth proxy), phpMyAdmin	Không tài khoản → 401
8	**Read-only rootfs**	`read_only: true` + `tmpfs` cho `/tmp` ở app, nginx, prometheus, loki, promtail, phpmyadmin	Trong compose
9	**Giới hạn tài nguyên**	`deploy.resources.limits` cho memory/CPU mọi service	Trong compose
10	**Healthcheck & phụ thuộc**	App và MySQL có healthcheck; Nginx chỉ khởi động sau khi app healthy	`kho-app Up (healthy)`, `kho-mysql Up (healthy)`
11	**Giới hạn log**	Driver `json-file`, `max-size=10m`, `max-file=3`	`/etc/docker/daemon.json`

---

5. KIỂM THỬ VÀ ĐÁNH GIÁ CHẤT LƯỢNG

Chi tiết đầy đủ nằm trong `docs/quality-checklist.md`. Tóm tắt những gì đã **thực sự chạy**:

5.1. Kiểm thử chức năng

NGHIỆP VỤ	CÁCH KIỂM TRA	KẾT QUẢ
Đăng nhập / đăng xuất	Thao tác thật trên trình duyệt	Đạt — session cookie `httpOnly`, `sameSite=Lax`
Ghi nhập hàng	Chọn NCC + 1 mã hàng + 40 đơn vị, lưu	Đạt — sinh phiếu `NH-2026-0039`, tồn tăng đúng 40
Ghi xuất hàng	Xuất 5 đơn vị	Đạt — sinh phiếu `XH-2026-0023`, tồn giảm 80 → 75
Chặn xuất vượt tồn	Xuất 99 999 đơn vị khi còn 75	Đạt — cảnh báo tại dòng *"Vượt tồn hiện có (75 cái)"*, server trả lỗi *"Tồn kho không đủ để xuất: DT-0034 (còn 75, cần 99999)"*, tồn **không đổi**
Thêm / sửa / xoá mã hàng	Thao tác thật	Đạt — có toast *"Đã thêm sản phẩm TEST-001."*
Lọc danh mục, tồn kho, sổ kho	Truy vấn `?q=`, `?filter=`, `?type=`	Đạt — lọc theo từ khoá cho 1 dòng, `filter=low` cho 9 dòng, `type=OUT` cho 20 dòng
Phân trang	28 mã hàng / 12 trang	Đạt — 3 trang, trang 3 còn 4 dòng
Console trình duyệt	`bsk console` sau mỗi lượt	Đạt — *"no console messages captured"*

5.2. Kiểm thử giao diện và trải nghiệm

- **Responsive**: đo trực tiếp `scrollWidth` / `clientWidth` ở 390 px trên cả 6 trang → **không tràn ngang** (sau khi sửa lỗi ô lưới không co lại được).
- **Tiếng Việt**: kiểm tra dấu ở cả 4 weight trên trình duyệt — đạt.
- **Bàn phím**: Tab dừng ở các mục điều hướng, focus hiện viền 2 px màu primary.
- **Giảm chuyển động**: `prefers-reduced-motion: reduce` → `transitionDuration = 0,01 ms`.
- **Tương phản**: đo bằng công thức WCAG 2.1 cho từng cặp màu trong design system.
- **Tốc độ**: các trang dữ liệu trả về trong **53 – 111 ms** trên mạng nội bộ.

5.3. Lỗi phát hiện và đã sửa trong quá trình làm

LỖI	BIỂU HIỆN	NGUYÊN NHÂN	CÁCH SỬA
KPI "Phiếu 30 ngày" hiển thị `3.422`	Nối chuỗi `"34" + "22"` trong JavaScript	MySQL trả `SUM()` dạng chuỗi	Ép kiểu `Number()` trước khi cộng
Tràn ngang ở 390 px	`scrollWidth` 658 > `clientWidth` 390	Ô lưới có `min-width: auto`, bị bảng trong đẩy rộng	Thêm `min-width: 0` cho item của lưới
Nút menu hiện trên desktop	Nút "Mở menu" xuất hiện ở khung 1440 px	`.btn` đè lên `.topbar__toggle` (cùng độ ưu tiên, file CSS đặt sau)	Tăng độ ưu tiên selector
Thông báo vượt tồn bằng tiếng Anh	Trình duyệt chặn submit bằng thông báo native	Thuộc tính `max` trên ô số lượng	Bỏ `max`, thêm cảnh báo tiếng Việt ngay tại dòng, vẫn để server kiểm tra
Ứng dụng treo không phản hồi	Mọi request đều timeout	Middleware `metrics` **quên gọi** `next()` nên chuỗi middleware dừng	Bổ sung `next()`
Nginx không khởi động	`unknown directive "#"`	File cấu hình bị **BOM** (UTF-8 BOM) do công cụ soạn thảo Windows	Ghi lại file không BOM
Nginx lỗi `chown ... Operation not permitted`	Container restart liên tục	`cap_drop: ALL` chặn `CHOWN` lúc khởi động	Cấp đúng 4 capability tối thiểu
phpMyAdmin báo lỗi đọc cấu hình	`Failed to open stream`	Đường dẫn trong image là `/etc/phpmyadmin` (chữ thường) nhưng mount `/etc/phpMyAdmin`	Sửa đường dẫn mount (Linux phân biệt hoa thường)
mysqld_exporter không đăng nhập được	`Access denied ... (using password: NO)`	Exporter chỉ đọc mật khẩu từ file `.my.cnf`, không đọc biến môi trường	Sinh `my.cnf` từ `.env`; tách `host` và `port` thành hai dòng
Grafana "Failed to load dashboard"	Panel báo *No data*	Dashboard tham chiếu datasource bằng placeholder `${datasource}`	Ghim UID thật (`prometheus`, `loki`) trong provisioning

6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Hệ thống đã hoàn thành đầy đủ 6 yêu cầu chung và 7 tiêu chí đánh giá của đề tài:

TIÊU CHÍ	KẾT QUẢ
1. Quản lý mã nguồn trên GitHub	Repository `DTC245200428`, 5 commit theo mốc, README hướng dẫn chạy đầy đủ
2. Triển khai ứng dụng + DB	11 container chạy bằng Docker Compose; MySQL 8.0.46 + phpMyAdmin 5.2.3 với 7 bảng và dữ liệu mẫu
3. Nginx reverse proxy	HTTP 8080 → 301 → HTTPS 8443, chứng thư tự ký, 6 security headers, basic auth cho công cụ quản trị
4. Prometheus + Grafana	4/4 mục tiêu `up`, 792 chỉ số MySQL, dashboard 8 panel provision sẵn, 4 luật cảnh báo
5. Loki + LogQL	5 truy vấn LogQL chạy thật, gom log 11 container qua Promtail
6. Hardening	11 biện pháp: non-root, network isolation, mật khẩu mạnh, hạn chế quyền DB, read-only rootfs, cap_drop, security headers, giới hạn tài nguyên, healthcheck, giới hạn log, xác thực hai lớp
7. Tổng thể & trình bày	Hệ thống chạy hoàn chỉnh bằng `docker compose up -d`; 17 ảnh chụp từ hệ thống đang chạy; báo cáo này

6.2. Hướng phát triển

1. **Quản lý nhiều kho và vị trí lưu kho** — bổ sung bảng `locations`, cho phép tồn theo từng khu vực, phục vụ nghiệp vụ 3PL.
2. **Quản lý lô/serial và hạn sử dụng** — thêm bảng `product_batches`, cảnh báo hàng sắp hết hạn.
3. **Đơn hàng bán ra** — dùng cột `stocks.committed` đã dự phòng để trừ lượng đã cam kết, tách *tồn thực* và *khả dụng*.
4. **Quét mã vạch bằng điện thoại** — ứng dụng đã responsive ở 390 px, sẵn sàng bổ sung chức năng quét và chế độ nhập nhanh.
5. **Cảnh báo chủ động** — nối luật cảnh báo Prometheus với Alertmanager để gửi cảnh báo qua email/Telegram.
6. **Sao lưu tự động** — thêm service `backup` định kỳ `mysqldump` vào volume riêng, kèm lịch giữ lại.

6.3. Bài học kinh nghiệm

- Docker Compose cho phép cô lập toàn bộ hệ thống chỉ bằng một lệnh, nhưng mỗi dịch vụ nằm trong một container riêng thì đường dẫn cấu hình, quyền sở hữu tệp và ký tự BOM đều trở thành nguồn lỗi — cần kiểm tra log container ngay khi triển khai.
- Đo tương phản màu và kiểm tra tiếng Việt ngay từ đầu giúp tiết kiệm thời gian sửa giao diện về sau.
- Ghi log ra `stdout` thay vì ghi tệp là điều kiện tiên quyết để hệ thống log tập trung bắt được log của web server.
- Phân quyền ở hai tầng (mạng nội bộ + basic auth + đăng nhập ứng dụng) cho phép mở đường dẫn quản trị mà không phải hy sinh bảo mật.

---

7. TÀI LIỆU THAM KHẢO

1. Odoo 19 Documentation — *Inventory dashboards*. https://www.odoo.com/documentation/19.0/applications/inventory_and_mrp/inventory/warehouses_storage/reporting/dashboards.ht
2. Microsoft Dynamics 365 Business Central — *Inventory and warehouse reports and analytics*. https://learn.microsoft.com/en-us/dynamics365/business-central/inventory-wms-reports
3. StockFlow — *Warehouse operations with a real stock ledger*. https://www.stock-flow.dev/
4. StockSight — *Real-time inventory analytics dashboard (Flask + MySQL)*. https://github.com/NagaprajwalB/StockSight
5. Docker Documentation — Compose file reference, networks (`internal`), resource limits, healthcheck. https://docs.docker.com/
6. NGINX Documentation — Reverse proxy, `stub_status`, `auth_basic`, security headers. https://nginx.org/en/docs/
7. Prometheus Documentation — Configuration, metric types, alerting rules. https://prometheus.io/docs/
8. Grafana Documentation — Provisioning (datasources, dashboards), auth proxy. https://grafana.com/docs/grafana/latest/
9. Grafana Loki Documentation — LogQL queries, `count_over_time`, label filters, regex parser. https://grafana.com/docs/loki/latest/
10. Promtail Documentation — Docker service discovery, `docker_sd_configs`. https://grafana.com/docs/loki/latest/send-data/promtail/
11. Node.js, Express, EJS, MySQL 8 documentation. https://nodejs.org/ · https://expressjs.com/ · https://ejs.co/ · https://dev.mysql.com/doc/
12. Be Vietnam Pro (SIL OFL 1.1) · Lucide (ISC) · Chart.js (MIT) — giấy phép tài nguyên trong `public/vendor/licenses/`.

---

8. PHỤ LỤC

8.1. Danh mục dịch vụ và cổng

SERVICE	CỔNG TRONG CONTAINER	CỔNG CÔNG KHAI	GHI CHÚ
nginx	8080, 8443	**8080, 8443**	Điểm vào duy nhất
app	3000	–	Chỉ trong `kho-net`
mysql	3306	–	Chỉ trong `kho-db` (internal)
phpmyadmin	80	–	Qua `/phpmyadmin/`
prometheus	9090	–	Qua `/prometheus/`
grafana	3000	–	Qua `/grafana/`
loki	3100	–	Qua `/loki/`
promtail	9080	–	Chỉ trong `kho-net`
node-exporter	9100	–	Chỉ trong `kho-net`
mysql-exporter	9104	–	Chỉ trong `kho-net`
nginx-exporter	9113	–	Chỉ trong `kho-net`

8.2. Tài khoản demo

HỆ THỐNG	TÀI KHOẢN	MẬT KHẨU
Ứng dụng	`admin`	`Kho@2026`
MySQL (phpMyAdmin)	`kho_app`	trong `.env` (`MYSQL_PASSWORD`)
Grafana / basic auth Nginx	`monitoring`	trong `.env` (`MONITORING_PASSWORD`)
Grafana admin (quản trị)	`admin`	trong `.env` (`GRAFANA_ADMIN_PASSWORD`)

> Toàn bộ mật khẩu thật được sinh ngẫu nhiên bằng `openssl rand` và lưu trong `.env` – **không** có trong mã nguồn. Bảng trên chỉ liệt kê tài khoản mẫu của ứng dụng (`admin` / `Kho@2026`) do `scripts/seed.js` tạo.

8.3. Ảnh minh họa

ẢNH	NỘI DUNG
`01-tong-quan-desktop.png`	Tổng quan kho (bản chạy cục bộ)
`02-ton-kho-desktop.png`	Danh sách tồn kho với bộ lọc trạng thái
`03-danh-muc-san-pham.png`	Danh mục sản phẩm
`04-phieu-nhap-hang.png`	Phiếu nhập hàng nhiều dòng
`05-lich-su-giao-dich.png`	Sổ kho, lọc theo loại phiếu
`07-tong-quan-mobile.png`	Tổng quan ở khung nhìn 390 px
`11-docker-dashboard.png`	Tổng quan khi chạy trong Docker Compose (qua Nginx + TLS)
`12-phpmyadmin.png`	phpMyAdmin – bảng `kho_hang` trong MySQL 8.0.46
`13-grafana.png`	Grafana (đăng nhập qua auth proxy của Nginx)
`14-prometheus-targets.png`	Prometheus – 4 mục tiêu đều `up`
`15-grafana-dashboard.png`	Dashboard giám sát với số liệu thật

8.4. Lệnh vận hành thường dùng

```
docker compose ps                # trạng thái 11 container
docker compose logs -f app       # log ứng dụng
docker compose restart app       # khởi động lại ứng dụng
docker compose exec mysql mysql -ukho_app -p kho_hang -e "SELECT COUNT(*) FROM stock_movements;"
docker compose down              # dừng toàn bộ (giữ dữ liệu)
docker compose down -v           # dừng và xoá volume
```